Layered Security Architecture

Privacy-preserving federated learning across regulated healthcare institutions

SYS **Secure Multi-Institutional Healthcare FL System**

L0 Governance, Consent and Compliance

- Consortium CA
  Hospital identity and roles
- Consent Registry
  purpose, scope, expiry, revocation
- Governance Policy
  retention, access and incident rules

Consent

Policy

L1 Local Healthcare Data Layer

- Hospitals A, B, C ... N
- Consent and
  purpose check
- Local preprocessing
  feature extraction and normalization
- Local healthcare dataset
  raw data never leaves hospital

Local data

L2 Distributed Cryptographic Setup

- Key rotation
  and revocation
- Distributed
  key generation
- Collective CKKS
  public key
- Threshold secret-key shares
  t-of-n hospitals
- Key shares protected by
  HSM or secure enclave

Public key

L3 Privacy-Safe Local Training

Repeat L3-L6

- Local model
  training
- Per-client
  gradient clipping
- Gaussian
  DP noise
- Privacy accountant
  epsilon and delta
- DP-safe adaptive
  compression
- Padded sparse encoding
  hide data-dependent
  payload size
- CKKS
  encryption
- Digital signature + round ID
  nonce and timestamp

Key shares

Signed update

L4 Secure Communication and Trust

- Mutual TLS
  secure channel
- Verify certificate, signature,
  nonce and round freshness
- Smart-contract admission
  identity and reputation policy
- Clipping-bound proof or
  trusted execution attestation
- Encrypted updates
  stored off-chain
- Permissioned ledger stores only
  hash, signature, timestamp
  and status

Off-chain ciphertexts + ledger status

L5 Secure and Poisoning-Resilient Aggregation

- Minimum-client quorum
  dropout-tolerant collection
- Reputation-aware weighted
  homomorphic FedAvg
- t-of-n threshold decryption
  aggregate only
- Candidate model validation
  quality, drift and anomaly checks
- **Validation passed?**
  - Yes → **Accept global model**
  - No → Reject round, rollback
    and quarantine suspects
- Update reputation
  and audit evidence

Accepted model

Accepted model

L6 Verified Distribution

- Record global-model hash
- Signed secure broadcast
- Hospitals verify
  version and hash
- Begin next FL round

L7 Privacy-Preserving Clinical Inference

- Authenticated
  encrypted request
- Consent and
  authorization check
- Encrypted or
  confidential inference
- Threshold or enclave decryption
  prediction result only
- Output minimization, rate limiting
  and audited clinical decision support

Color key: governance | privacy | cryptography | trust/audit | verified operation | rejection

Long connectors use perimeter rails to preserve layer readability.